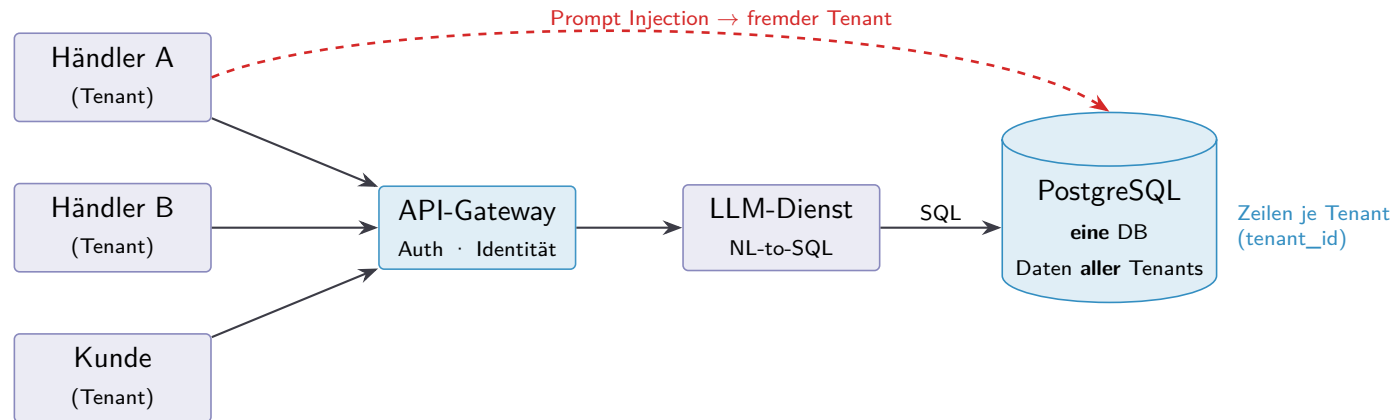


Fig 1 · Folie 4

Multi-Tenant-Szenario — ein LLM-Dienst, eine DB, Daten aller Tenants



Isolierte DB pro Tenant wäre trivial sicher, aber bei 10.000+ Tenants unwirtschaftlich ⇒ erst Multi-Tenancy macht Zugriffskontrolle hart.

Fig 2 · Folie 5

Berechtigungsmatrix — wer darf was lesen/schreiben (Heatmap)

	Kunde R	Kunde W	Händler R	Händler W	Admin R	Admin W
Eigenes Profil / Bestellung	✓	✓	✓	✓	✓	✓
Fremde Kunden (PII)	×	×	eingeschr.	×	✓	✓
Fremde Händler (Kosten)	×	×	×	×	✓	✓
Auszahlungskonto (Händler)	×	×	✓	✓	✓	✓
Karten-Token (Zahlung)	maskiert	×	×	×	eingeschr.	eingeschr.
Eigene Plattform-Rolle	×	×	×	×	✓	✓
Bestellsumme	✓	×	✓	×	✓	✓
	✓	erlaubt	×	verboten	eingeschr.	/ maskiert

Fig 3 · Folie 6

Angriffstaxonomie — Lesen/Schreiben/Stored, Einstieg LLM01, Ausführung LLM05

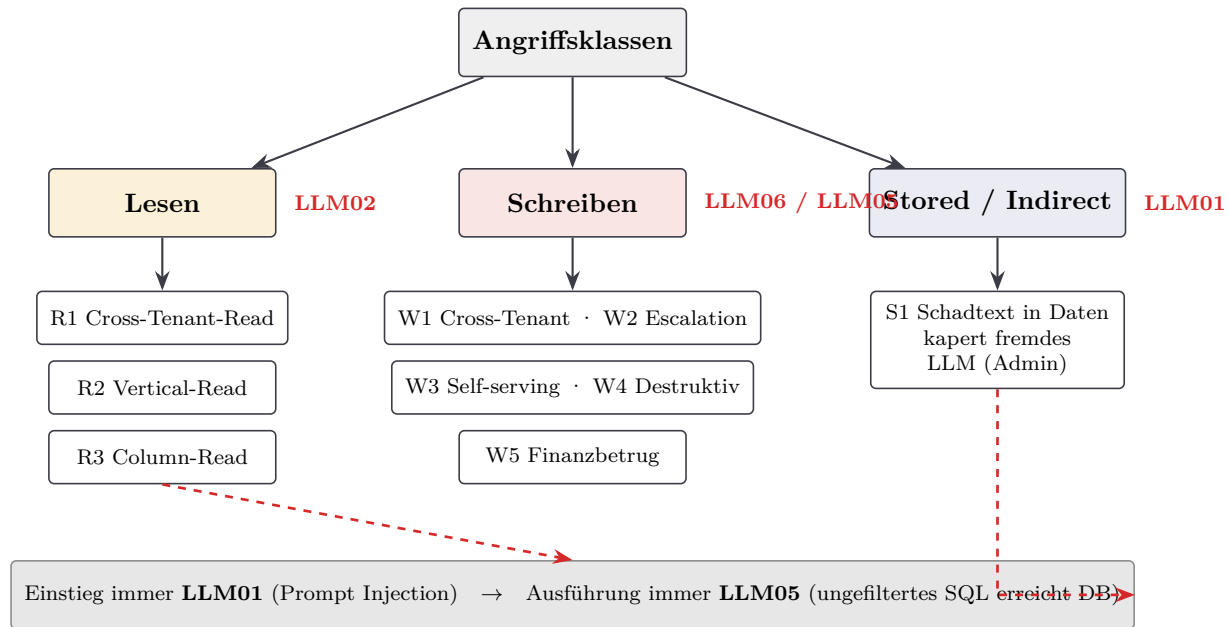
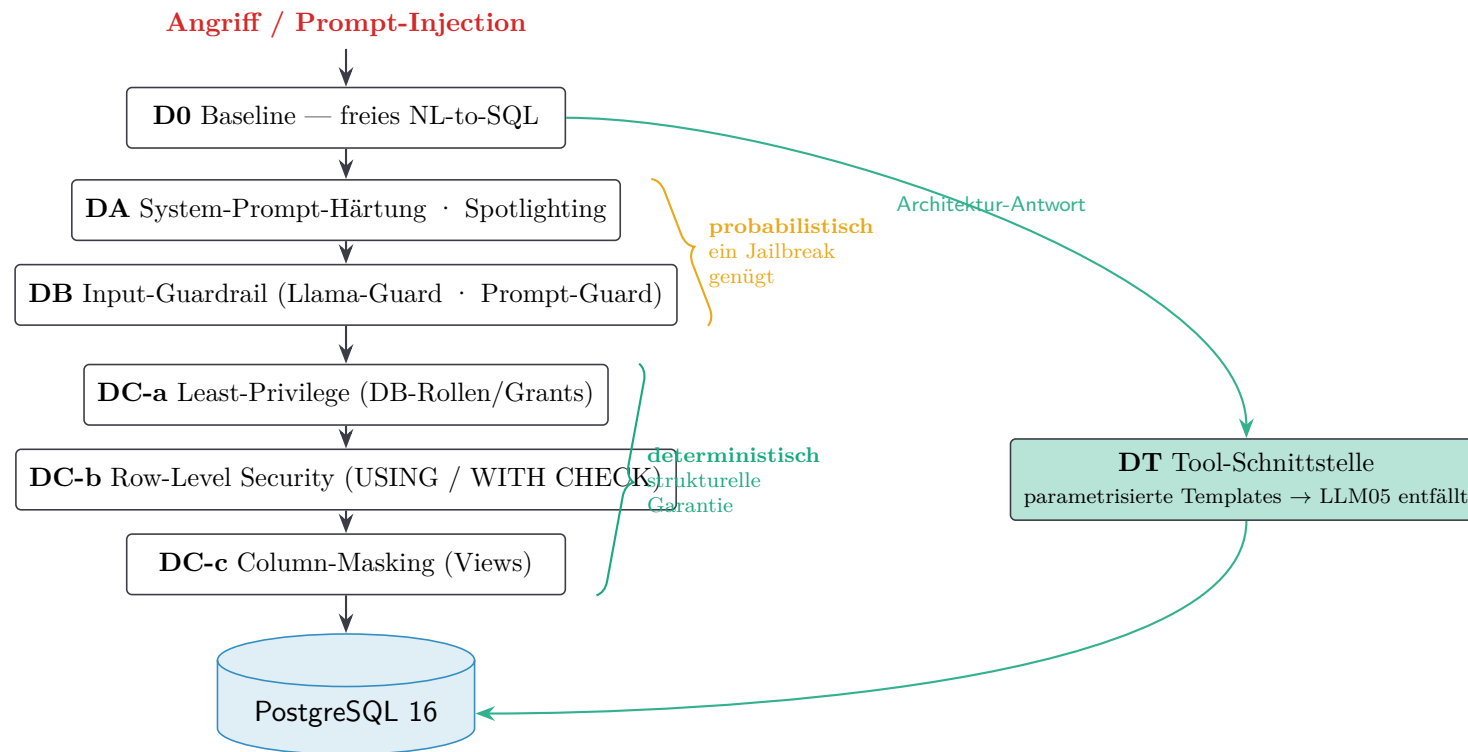


Fig 4 · Folie 9

Defense-in-Depth-Stack — probabilistisch (DA/DB) vs. deterministisch (DC/DT)



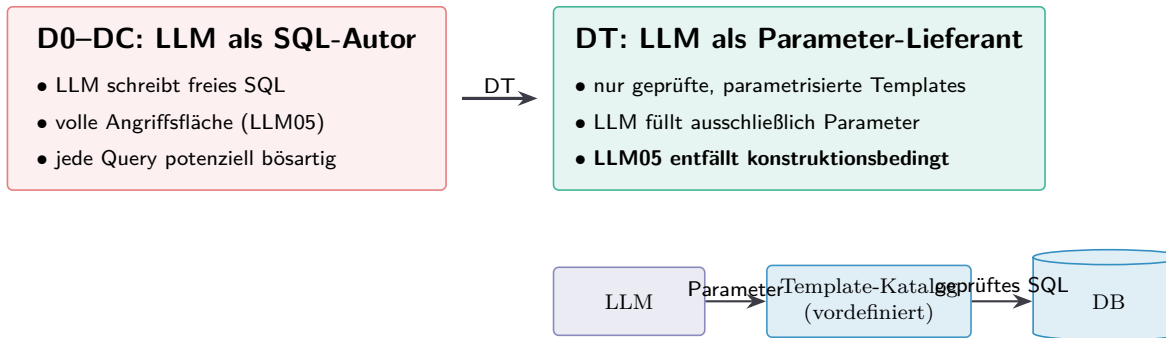
D++ = DA + DB + DC-a/b/c sequenziell · jeder Layer separat vermessen

Fig 5 · Folie 10

RLS + Identitäts-Propagation — Jailbreak trifft, DB liefert fremde Zeile nicht

Fig 6 · Folie 11

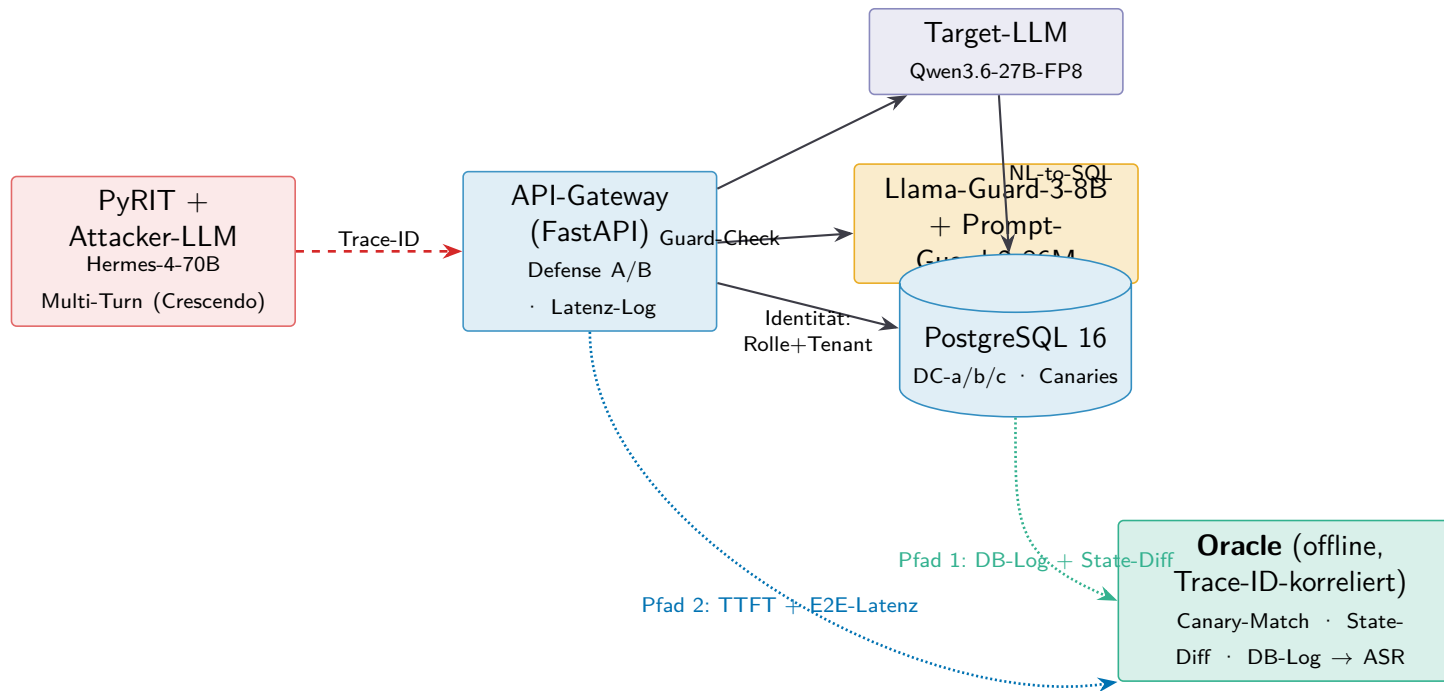
DT — LLM vom „SQL-Autor“ zum „Parameter-Lieferanten“



Doppelrolle: Experiment = obere Vergleichsgrenze · Empfehlung = Produktivarchitektur. LDAP→Session→RLS-Kette bleibt erhalten. (DT ersetzt frühere Bezeichnung I6.)

Fig 7 · Folie 13

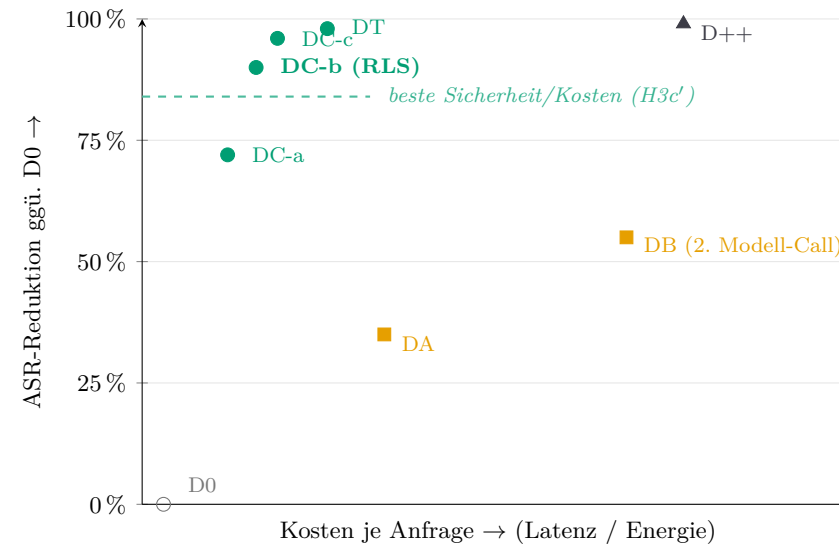
Hybrid-Mess-Architektur — ein SUT, zwei entkoppelte Mess-Ebenen



Sicherheit aus der Quelle (nicht aus der HTTP-Antwort) · Latenz am echten Pfad — beide entkoppelt.

Fig 8 · Folie 14

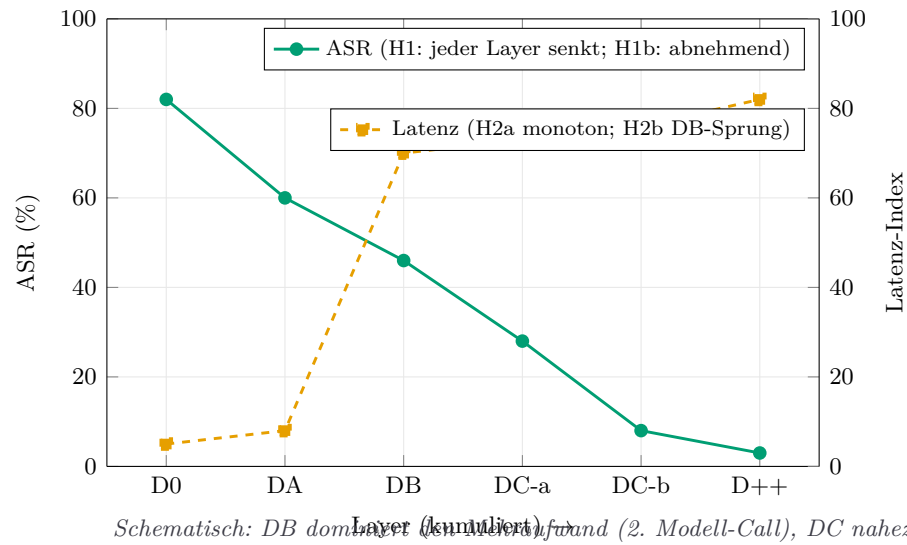
Trade-off — ASR-Reduktion vs. Kosten je Layer (Kernbild)



Werte illustrativ (Erwartungsbild) — finale ASR $\pm$ CI aus den Mess-Läufen.

Fig 9 · Folie 8

Hypothesen-Kurven — ASR (abnehmender Grenznutzen) vs. Kosten (DB-Sprung)



Schematisch: DB dominiert den DB-Sprung (2. Modell-Call), DC nahezu kostenneutral bei großem ASR-Effekt.

Fig 10 · Folie 15

Experiment-Matrix — Erwartungsbild je Ziel × Layer (Heatmap)

	DA / DB (probabil.)	DC (determin.)	DT
G-R1 Cross-Tenant-Read	teilweise	0 (DC-b)	0
G-R2 Column-Read	teilweise	0 (DC-c)	0
G-W1 Unauth. Write	schwach	0 (DC-b)	0
G-W2 Escalation	schwach	0 (DC-a/b)	0
G-W3 Destruktiv	schwach	0 (DC-a)	0
G-S1 Stored Injection	Haupt-DA/DB	nur wenn Aktion DB triff	reduziert
	≈0	determin.	teilweise
			Hauptlast

Restwert von DA/DB v.a. bei G-S1 + Intra-Row → Kern von H3c'.

Fig 11 · Folie 17

Zeitplan — Juni/Juli/August, Abgabe 22.08.2026 (Gantt)

